WOODEX INTERIOR - DIGITAL OPERATIONS

Master Plan

Website, backend, admin v2.0 to v2.5, security, releases and marketing

Date	15 October 2026
Scope	Whole project: production, repository, 15 branches, 7 PRs, Drive, Linear, 5 competitors
Builds on	p23.md (13 Oct analysis) + ADMIN-V2.5-MASTER-PLAN-2026-10-13
Verdict	Contain today; one line (v2.5); proof-led marketing
Branch	arena/9e181806-marketingwoodex

Woodex Interior - Master Plan, 15 October 2026

One plan for the whole project: the live website, the PHP/MySQL backend, the admin (v2.0 in production, v2.5 in build), security, releases and marketing. It builds on the 13 October analysis (p23.md). Everything was re-measured today against production, the repository, every branch and pull request, Google Drive, Linear and five competitors.

Item	Detail
Date	Thursday 15 October 2026
Prepared on	branch arena/9e181806-marketingwoodex; its base 720d817 is the head of PR #4 = main + 3 commits made today
Inputs	production woodex.com.pk (read-only page checks) - this repository (2,745 tracked files) - 15 remote branches and 7 PRs via the GitHub API - ADMIN-V2.5-MASTER-PLAN-2026-10-13.md and WORK-SANDBOX-MEMORY.md from the v2.5 branches - Google Drive (Woodex files and their sharing) - Linear (team MAR) - aenzay.com, mavric.pk, hiline.pk, spacezandplaces.com, interioreight.com
Replaces	the roadmap in p23.md and the older root plans (MASTER-PLAN.md, MASTER-PLAN-P16...P19.md, BACKEND-MASTER-PLAN.md, WOODEX-ADMIN-V2-MASTER-PLAN.md, HOSTINGER-MASTER-PLAN.md, LIVE-AUDIT-AND-MASTER-PLAN.md). Decisions from them that still hold are carried forward here.
Keeps	ADMIN-V2.5-MASTER-PLAN-2026-10-13.md as the design specification of v2.5. This plan adopts it and schedules it.
Convention	No password, token or key appears in this document. Findings cite file:line or a URL. Nothing was signed into and no credential was tried.

How to read it. Owner: section 1, then Appendix A today. Developers: sections 4, 6 and 8. Marketing: section 7.

1. Executive summary

1.1 The verdict

Question	Answer
Is production safe today?	No - act today. Four public files on woodex.com.pk publish credentials or run installer tools. /downloads.html shows an admin e-mail and password in plain text. /wx-demo.php lists four demo logins and their password. /wx-install.php resets an owner password for anyone who has the database password. /wx-check.php shows server and database details. The sign-in page itself says a fresh install logs in as admin / admin. Database and bot credentials are still published on two public branches (PR #5, PR #6). Together these are a path to taking over the admin.
Is the product good?	Yes. The public site is technically strong: 142 indexable pages, 0 broken internal links out of 14,065, structured data on every page, an AI-crawler policy and llms.txt. The backend runs a real business: about 350 actions over 20 MySQL tables, plus WhatsApp, Telegram, Google and AI integrations.
What is actually wrong?	Process, not code. Several agent sessions are building competing versions at once: PR #4 was pushed at 04:33-04:45 UTC today, PR #7 at 04:54-04:57, branch 5dbf5461 yesterday. Nothing has reached main since 8 October. Production matches no single commit. A commit titled "security containment" added two new credential risks.
The one decision	Make v2.5 (PR #7) the only development line. Keep v2.0, which production runs, in security-fix-only mode as the rollback path. Freeze and close the v2.1 line (PR #4, #5, #6) after taking four useful pieces from it.
The biggest growth lever	Proof. The Woodex company profile (V25) lists 30+ named projects: Peshawar Zalmi, UMT, Devsinc, Hotel One, Jotun, Al Haram City and others. The website shows none of them; all six "case studies" are marked Illustrative. Every competitor reviewed leads with at least one of: named work, a logo wall, a named principal, reviews, social profiles. Woodex links to no social profile at all.

1.2 What success looks like

By	Outcome
Sat 17 Oct (48 h)	The five risky files are off the server; every password, token and key is rotated; the repository is private.
Fri 23 Oct (week 1)	One source of truth: main is canonical, CI runs on every PR, stale PRs are closed, 5dbf5461 is folded into PR #7.
Fri 13 Nov (week 4)	Hotfix P22.2 is live and production matches its manifest; v2.5 runs beside v2.0 at /admin-next/ and has passed the host gate; Google Business Profile, social links and NAP are fixed; the first 4 real case studies are live.
Fri 22 Jan 2027 (week 14)	v2.5 covers daily operations (leads -> quotes -> invoices -> payments) and /admin/ switches to it; the reviews engine and diaspora landing page run; 8+ real case studies are live.
April 2027	Client portal, payment gateway and AI scope generator are in production (v2.5 Phase 6).

2. What changed since the 13 October analysis

2.1 New facts

#	Fact	Evidence
N1	v2.5 moved fast. PR #7 is now 82 commits ahead of main, and release P25.1 was published today at 04:57 UTC. Its gates report 1,283 API tests passing (0 failing, 14 skipped) and 86 conformance checks. It deletes the old admin/, wf-admin/, woodex-vlive-P20/ and P15-P20 deploy/ material (1,045 files, about 67 MB) and removes demo mode.	gh release view p25; PR #7
N2	A second v2.5 tip, arena/5dbf5461 (no PR), holds 11 commits PR #7 lacks: api/v2 running on SQLite under PHP-in-WebAssembly, a dev seeder, schema and code mismatch fixes that also affect MySQL, and a fix for a client project link that returned HTTP 500.	GitHub compare 4150341e...5dbf5461: 11 ahead, 16 behind
N3	PR #4 was force-rewritten today to main + 3 commits. The p29 v2.1-pro trees, with their .env and config.php, are gone from it. The new commits add useful fixes and new risks (S-05, S-06, D-01). They also make root admin/ a second copy of frontend-v1/admin/, while PR #7 deletes that folder.	git log 782b50b..720d817
N4	Production runs the v2.0 admin ("Woodex Admin"). v2.5 has never been deployed (/api/v2/health returns 404). The live sitemap is dated 8 Oct and lists /downloads.html and /blocks.html. Those two files exist only in the v2.1-pro tree on PR #5/#6, not in frontend-v1/.	live checks, 15 Oct
N5	Google Drive: the "Woodex - Admin v2.5 (P25)" folder is shared with anyone with the link and holds 5 copies of the 29 MB payload. The SQL dumps checked are private, which is good.	Drive permissions
N6	Linear has a team (MAR, "Marketing woodex") holding only Linear's four onboarding issues. No backlog exists anywhere.	Linear
N7	A benchmark against five Lahore studios is in section 7.	fetched 15 Oct

2.2 Corrections to the 13 October analysis

#	p23.md said	Measured today
C1	DB-1: five tables (wx_allowed, wx_caps, wx_user_perms, wx_action_group, wx_role_groups) are created lazily and missing from the dump	They are PHP functions in roles-lib.php: one definition each, zero SQL references. The dump's 20 tables are complete. The v2.5 plan Section 9.1 already corrected this, yet PR #4 created the five as empty tables.
C2	FE-3: 143 images lack alt text	0 images lack an alt attribute. 374 carry alt="", and most are content photos of projects, areas and services. The fix is writing descriptions, not adding attributes.
C3	FE-4: downloads.html:70 reveals the admin hint	The file is not in frontend-v1/, but it is live on production and worse than reported: it prints an admin e-mail and password.
C4	SEC-001: login pre-fill and empty-password fallback	Not in frontend-v1/admin/, which production runs. It belongs to the v2.1-pro tree on PR #5/#6. Production instead shows an admin / admin hint (S-03).
C5	AD-1: duplicate fragments break parsing	Not in frontend-v1/admin/, where all 60 modules parse. Applies to v2.1 trees only.
C6	The root site is "legacy"	Correct. WORK-SANDBOX-MEMORY.md Section 2 is wrong to call it the newer "v26" site. On all six pages compared the root copy is shorter. It has 8 articles against 48, and 86 sitemap URLs against 142. It also posts to Netlify functions that decision D11 retired on 29 September.
C7	364 actions across 40 PHP files	A grep finds 348 distinct case labels across 40 files (6,848 lines); the v2.5 generator counts 365. The methods differ; use the generator's 365 as the reference.

3. Where the project stands

3.1 Production - woodex.com.pk, observed 15 October

Check	Result
Home page	Live, in the frontend-v1 design. Shows "since 2016 - 200+ completed spaces - 6 disciplines - 4 cities".
/admin/	v2.0 admin sign-in. The page says that after wx-install.php "you sign in with admin / admin" (from frontend-v1/admin/index.html:68).
/api/v2/health	404: v2.5 is not deployed.
/sitemap.xml	lastmod 2026-10-08. It includes /downloads.html and /blocks.html; the repository's sitemap (dated 12 Oct) does not.
/downloads.html	Live. Titled "Woodex Live v3 - Package Downloads", it shows an admin e-mail and password in plain text. It links to full-source zips on GitHub: one link died with the PR #4 rewrite, the P22.1 link still works. It calls the admin "v3" and "v2.5 Pro".
/blocks.html	Live and in the sitemap. An internal block catalogue ("Copy Block HTML") with public claims nobody can back up: a "1-Kanal DHA Phase 6 Villa - 100% VERIFIED", milestones "tracked in our client portal" (no portal exists), and a fixed PKR 4,850,000 estimate.
/wx-install.php	Live. The installer form. Given the current database password it re-runs and can reset an owner's password; 5 wrong tries lock it for 15 minutes (frontend-v1/wx-install.php:13-44).
/wx-demo.php	Live. Lists four demo logins and their shared password. Status is "not active", but anyone with the database password can activate them (frontend-v1/wx-demo.php:10).

Check	Result
/wx-check.php	Live. Shows PHP 8.3.35, the database name and user, 20 tables, and "6 users, 2 active owners".

> What is live matches no single commit. The public files come partly from the v2.1-pro tree (downloads.html, blocks.html, the 8 Oct sitemap) and the admin from v2.0. Five files must not be public. Fixing this is Phase 0 (today) and Phase 1 (inventory and manifest).

3.2 Branches and pull requests

The repository is **public** (isPrivate: false), with 15 branches and 7 PRs.

PR / branch	Line	State today	Action
main @ 782b50b (8 Oct)	v2.0 + P22.1 release	Last merge 8 Oct; not the development line	Becomes canonical again when PR #7 merges (Phase 1)
#7 arena/4150341e @ d042415	v2.5 (React console + api/v2)	82 commits ahead of main; P25.1 released today; tested	Canonical. Merge after the Phase 1 gate
arena/5dbf5461 @ c318143	v2.5	11 unique commits, 16 behind PR #7	Fold into PR #7, then delete
#4 arena/8a776c65 @ 720d817	v2.0 / v2.1	main + 3 commits (today)	Take 4 items (Appendix B), then close
#5 arena/4ba510f0	v2.1-pro	+549,502 / -35,770 lines, 4,972 files; contains .env and config.php	Close unmerged; delete after salvage
#6 arena/7f38fddd -> #5	v2.1-pro design batches	contains .env and config.php	Close unmerged; keep only as a design reference; delete
#1 arena/01a0e87c	Vercel/Supabase rebuild (29 Sep)	Superseded by D11	Close
#2, #3	-	Merged	-
9 other arena/* branches	earlier sessions	No PR	Delete after a quick check each

3.3 Scorecard

Area	Rating	Why
Public website (frontend-v1)	GREEN	Every indexable page has a title, description, canonical and one H1. 0 broken links. LocalBusiness, Service, FAQPage, BlogPosting and BreadcrumbList schema. WebP images, an AI-crawler policy. Gaps: 374 empty alts on photos, about 72 KB of inline CSS per page, no sameAs.
PHP API (frontend-v1/api, 44 PHP files)	AMBER	All files parse under the PHP 8 grammar. Weaknesses: non-atomic JSON writes on main; only PDOException caught (admin.php:600); the session secret regenerates after a failed read (admin.php:49); the token sits in sessionStorage (admin.js:209,467).
Database (20 tables)	AMBER	No foreign keys. Quotes, invoices and projects are stored as JSON text. The v2.5 migrations 000-014 are written but have never run on MySQL.
Admin v2.0 (production)	AMBER	57 routes, and all 60 modules parse. 12 screens are registered by 2+ modules (the last script wins). No tests.

Area	Rating	Why
Admin v2.5 (PR #7)	AMBER - promising	1,283 API tests, 86 conformance checks, a typed console, a release builder with a manifest. Not deployed, and the quotation builder and pipeline screens were removed as prototypes, so it cannot run sales yet.
Security	RED	Live credential pages and installer tools; a public repository with credentials on two branches; new risks in PR #4.
Releases and repository hygiene	RED	Production differs from the repository; 29 zips (184 MB) in Git; four admin generations; 24 reports at the root; no CI.
Integrations	AMBER	WhatsApp Cloud API, Telegram, GA4/Search Console, Sheets, AI and MCP exist. Netlify functions, Supabase and a GitHub-publishing MCP server are dead weight.
Marketing and trust	RED	No real case studies, no social profiles, no named principal, no reviews on the site, and NAP differs between the site and the company profile, despite excellent content depth.
Process	RED	Parallel agent sessions, no backlog, no branch protection, nothing merged in a week.

4. Findings register

Severity: **Critical** = fix within 48 hours - **High** = within 2 weeks - **Medium** = within 2 months - **Low** = when convenient. Owner: **O** = the business owner (needs hPanel, Google, Meta and GitHub admin access) - **D** = a developer or agent session.

4.1 Critical

ID	Finding	Evidence	Fix	Owner
S-01	An admin e-mail and password are published on a public page that is also in the sitemap	https://woodex.com.pk/downloads.html	Delete the file; remove it from the sitemap; request removal in Search Console; change that account's password	O
S-02	Installer and diagnostic tools are public. wx-install.php resets an owner password for anyone with the database password, and its 5-tries-per-15-minutes lockout still lets anyone guess that password slowly. wx-demo.php lists demo logins and can activate them. wx-check.php discloses server and database details.	live URLs; frontend-v1/wx-install.php:13-44; frontend-v1/wx-demo.php:10	Delete all three from the server; exclude them from every release; add a deny rule in .htaccess as a second wall	O + D
S-03	The sign-in page and the API advertise the first-install login admin / admin	frontend-v1/admin/index.html:68; frontend-v1/api/admin.php:359; frontend-v1/wx-install.php:4,44,80	Remove the hints; make sure no admin account keeps a default password; turn on 2FA for owners	O + D
S-04	.env and config.php are published on public branches; per p23.md they hold database, bot and application keys	arena/7f38fddd and arena/4ba510f0: /.env, /config.php, woodex-live-p29-v2.1-pro/.env, .../config.php (existence checked, contents not opened)	Make the repository private; rotate every value those files configure; close PR #5/#6; delete the branches	O

ID	Finding	Evidence	Fix	Owner
S-05	PR #4's "25-table DDL" seeds 4 accounts (2 owners, 1 admin, 1 editor) that share one password hash. That hash matches a password published in this repository. The ON DUPLICATE KEY UPDATE pass_hash..., active = 1 clause means importing the file resets real accounts with those e-mails to that password.	woodex-database.sql:306-312 and the identical frontend-v1/_database/woodex-database.sql:306-312	Never import it. Delete the seed block; accounts are created by the installer or db/owner.php	D
S-06	PR #4 adds a password bypass to the Node preview backend: any account accepts two common passwords. It also reads u.pass_hash before checking that u exists, so an unknown user crashes the request.	tools/frontend-v1-admin.mjs:2386-2388	Revert those three lines	D

4.2 High

ID	Finding	Evidence	Fix	Owner
R-01	Production matches no commit, so nobody can prove which build is live	section 3.1	Inventory public_html (file list + SHA-256), compare it with a release manifest, then deploy only manifest-tied packages	O + D
R-02	Two development lines collide: PR #4 rewrites root admin/ and PR #7 deletes it; 5dbf5461 holds 11 unmerged v2.5 commits	section 3.2	Phase 1 consolidation	D
R-03	No CI, no branch protection, nothing merged to main since 8 Oct	no .github/ on this line	Add CI (Phase 1) and protect main	O + D
W-01	/blocks.html, an internal catalogue indexed by Google, makes unverifiable public claims	section 3.1	Delete it; remove it from the sitemap; request removal in Search Console	O
B-01	Production writes its JSON stores non-atomically (it truncates, then locks)	frontend-v1/api/admin.php:37 and forms.php:24 on main	Ship PR #4's temp-file + rename fix (bd53b01) in hotfix P22.2	D
B-02	If the session-secret file reads empty, the secret is regenerated and every session ends	frontend-v1/api/admin.php:49	Regenerate only when the file is truly absent, and log it (v2.5 keeps the secret in MySQL)	D
B-03	Only PDOException is caught, so any other error becomes a blank 500	frontend-v1/api/admin.php:600	Catch Throwable and log with a request id (the v2.5 front controller already does)	D
B-04	The admin token is kept in sessionStorage, so a single XSS bug means account takeover	frontend-v1/admin/admin.js:209,467	v2.5 uses an HttpOnly cookie + CSRF; until then, a strict Content-Security-Policy on /admin/	D
A-01	v2.5 cannot replace v2.0 yet: it is not deployed, its migrations have never run on MySQL, and P25.1 removed the quotation builder and pipeline screens	/api/v2/health 404; P25.1 release notes	Phases 2-4	D
A-02	The v2.5 approval queue stores the request body verbatim, so a manager saving an API key writes it into the approvals table	WORK-SANDBOX-MEMORY.md Section 8c2, item 4	Strip secrets from queued bodies (re-enter them on approval) or encrypt them	D
M-01	The website shows no real projects: the six studies are labelled Illustrative, while the company profile lists 30+ named projects	frontend-v1/projects/*; Drive: Company Profile V25	Proof sprint (section 7.3)	O + D

ID	Finding	Evidence	Fix	Owner
M-02	Entity and NAP gaps. There are no social links and no sameAs. The company profile (Woodex Furniture) gives a different office unit (LG-89 vs M-71 Zainab Tower), phone numbers and a Gmail address. It also contains the spam phrase "Hublot classic fusion replica office chairs".	frontend-v1/index.html; Drive: Company Profile V25	Decide the official NAP per brand; fix the site, the profile PDF, Google Business Profile and directories	O
O-01	The Drive "P25" folder is open to anyone with the link and holds 5 copies of the payload	Drive permissions	Keep one copy; share with named people only	O

4.3 Medium

ID	Finding	Evidence	Fix
W-02	374 content photos carry alt=""	static scan of all public pages	Write descriptive alt text (v2.5 plans a missing-alt queue in the media library)
W-03	About 72 KB of inline "critical" CSS on every page, against a target of 14 KB or less. The site stylesheet is 712 KB (88 KB gzipped), and assets/img/_orig/ copies are shipped.	frontend-v1/index.html, assets/site-p21.css	Trim critical CSS to above-the-fold rules; split the stylesheet per template; leave _orig/ out of releases
W-04	The old 87-page root site is still in the repository and posts to retired Netlify functions. Agents edit the wrong site, and the v2.5 sandbox reads it.	root index.html, contact/	Delete after decision D-3 (tag it first)
R-04	29 zip files (184 MB, inside about 237 MB of release folders) and 42 screenshots in Git; a 316 MB working tree	find . -name '*.zip'	Move releases to GitHub Releases or Drive; keep the repository source-only
R-05	Dead stacks from before decision D11: netlify/, netlify.toml, vercel.json, api/router.mjs, supabase/, wf-admin/, mcp-server/ (which publishes to main via Supabase), root admin/	tree	Delete (PR #7 already removes some)
A-03	Admin v2.0: 12 screens registered by 2+ modules; a static ?v=2.1.1 cache key; 67 script tags	frontend-v1/admin/*.js	Security fixes only; retire at cut-over
B-05	Keys passed in query strings end up in server logs	frontend-v1/api/mcp.php:34 (?key=), wa-cron.php (?key=)	Prefer the header; rotate the keys if logs were ever shared
B-06	The WhatsApp cron takes a non-blocking lock and admin writers take none, so campaign settings can be lost	frontend-v1/api/p18g-lib.php:94	One lock helper for both (v2.5 Phase 4)
D-01	PR #4 creates five empty "tables" named after PHP functions	woodex-database.sql	Do not carry it forward
D-02	Money is stored as JSON text, and there are no foreign keys	frontend-v1/_database/woodex-v20.sql	v2.5 migrations 003 (document columns) and 004 (foreign keys), staging first
O-02	No backlog: Linear holds only onboarding issues	Linear team MAR	The structure in section 8.4

4.4 Low

ID	Finding	Fix
L-01	24 reports and plans at the repository root	Move them to docs/ with an index; keep README.md and this plan at the root
L-02	The demo password literal appears in 63 test scripts under tools/	Read it from an environment variable in the test tools
L-03	The root robots.txt (old site) does not disallow /admin/	Goes away with W-04
L-04	README.md on main and the GitHub repository description hold a stray chat message instead of a description	PR #7 brings a real README; the owner updates the description (repository -> About -> Edit)
L-05	tools/report2pdf.py (v2.5 branch) divides widths that are already in millimetres by 2.83465, so table columns come out cramped and words split	Drop the two conversions (lines 306 and 314); share leftover width in proportion to content

5. Strategy and decisions

5.1 Why v2.5 is the line to build on

	v2.0 - production	v2.1 line - PR #4/#5/#6	v2.5 - PR #7
Where it lives	main / frontend-v1; live	three open PRs, two of them carrying credentials	PR #7 (+ 5dbf5461)
Screens	57 routes	57-64 routes	about 28 live of 65 registered; pipeline and quotation builder planned
Automated tests	none	none	1,283 API tests, 86 conformance checks, a 65-route render smoke test, tsc
Sign-in	HMAC token in sessionStorage	same	HttpOnly cookie + CSRF, 2FA, roles stored as data
Money	computed in the browser; stored as JSON text	same	computed on the server; a document-columns migration
JSON stores	non-atomic writes	atomic writes (PR #4)	an atomic store; migration 010 moves the stores into MySQL
Releases	zips in Git, no manifest	zips in Git	make-release.mjs: refuses credentials, writes a manifest
Deployed	yes	unknown	no
Verdict	maintain - security fixes only	freeze and close; salvage 4 items	the only development line

Why not keep polishing v2.1? Its structure causes the "fix one screen, break another" cycle seen in every audit since Phase 16: one global screen registry, script order as the router, no build step, no tests. v2.5 keeps what is valuable, the PHP business rules and the MySQL data. It replaces only the interface and the API envelope, one screen at a time, with v2.0 as the rollback path. Hosting stays Hostinger-only (decision D11), because the React console is just static files.

5.2 Target architecture (hosting unchanged)

```
woodex.com.pk -- Hostinger (LiteSpeed/Apache, PHP 8.3, MySQL u128159657_woodex)
public_html/
|- 142 pages, sitemap.xml, robots.txt, llms.txt frontend-v1, static HTML
|- api/ v2.0 API: security fixes only, until cut-over
|- api/v2/ v2.5 API: all new work; the 365 v2.0 actions bridged
|- admin/ v2.0 admin: rollback path; 302 to the v2.5 console at cut-over
|- admin-next/ v2.5 console: static React build; becomes /admin/ at cut-over
|- _private/ denied by .htaccess and a PHP guard; JSON stores -> MySQL (010)
'- never ship: wx-install/wx-check/wx-demo.php, downloads.html, blocks.html, *.zip
```

db/migrate.php and db/owner.php sit beside api/v2/ and run from the command line only. The integrations stay as they are: WhatsApp Cloud API, Telegram, GA4/Search Console, Google Sheets, AI, and MCP through api/mcp.php.

5.3 Decisions needed from the owner

#	Decision	Recommendation	Needed by
D-1	Which admin line is the future	v2.5 (PR #7); v2.0 security fixes only; close v2.1	17 Oct
D-2	Repository visibility	Private, and rotate anyway: history, forks and caches may already hold the values	16 Oct
D-3	The old 87-page root site	Delete it after tagging archive/root-site-2026-10; frontend-v1 is the website	23 Oct
D-4	Hosting	Hostinger only (re-confirm D11); remove the Netlify, Vercel and Supabase material	23 Oct
D-5	Which real projects may be published	Get written consent per client; start with 8 (section 7.3)	23 Oct
D-6	The official NAP (name, address, phone) per brand	Woodex Interior: the website's (M-71 Zainab Tower, +92 322 4000768, info@woodex.com.pk). Woodex Furniture: confirm the profile's, then use it everywhere.	20 Oct
D-7	Overseas-Pakistani (diaspora) market	Go: a landing page and an international WhatsApp line	6 Nov
D-8	Team capacity	2 developer-equivalents gives cut-over in mid-January 2027; 1 gives about April 2027	23 Oct
D-9	Payment gateway (Phase 6)	PayFast first, as the v2.5 plan recommends; JazzCash and EasyPaisa next	January 2027

6. Roadmap

Each phase ends with a **gate**: a check anyone can run. The next phase does not start until the gate passes.

Phase 0 - Containment - today -> Sat 17 Oct - owner-led, about 3 hours of work

#	Task	Owner
0.1	Download a backup of public_html and the database (hPanel)	O
0.2	Delete from public_html: downloads.html, blocks.html, wx-install.php, wx-check.php, wx-demo.php	O
0.3	In the admin: change every user's password (6 users per wx-check.php); disable accounts nobody recognises; check Activity for sign-ins since 8 Oct; turn on 2FA for both owners	O
0.4	Rotate: the MySQL password (hPanel, then _private/db.json), the page-builder password, the Telegram bot token (BotFather /revoke), the WhatsApp Cloud API token, the Google OAuth secret, the AI provider keys, the MCP tokens and the WhatsApp cron key	O

#	Task	Owner
0.5	GitHub -> Settings -> Danger zone -> Change visibility -> Private	O
0.6	Search Console -> Removals: /downloads.html, /blocks.html; resubmit the sitemap after 0.2	O
0.7	Agree that nobody imports woodex-database.sql from PR #4 and nobody merges PR #4/#5/#6	O + D

Gate 0: the five URLs return 404; the old database password no longer connects; the old bot token is rejected; gh repo view json isPrivate returns true; the admin Activity log has been reviewed.

Phase 1 - One source of truth - Mon 19 -> Fri 23 Oct

#	Task	Owner
1.1	Record decisions D-1 to D-4 and D-8 in this file and in Linear	O
1.2	Cherry-pick (or merge) the 11 5dbf5461 commits into PR #7; resolve the integrations overlap (82e60cfe vs c0d661b4); re-run the full v2.5 gate	D
1.3	Add CI (GitHub Actions) to PR #7: tests/run.php under php-wasm, tests/conformance.mjs, php-lint (over frontend-v1/ too), tsc, the smoke test, gen-aliases --check, and a secret scan (gitleaks)	D
1.4	Merge PR #7 into main; protect main (a PR and green CI required)	O + D
1.5	Close PR #1, #4, #5 and #6 with a salvage note (Appendix B); delete their branches and the 9 stale arena/* branches	O + D
1.6	Production inventory: list every file in public_html with its SHA-256 and diff it against frontend-v1/	D
1.7	Create the Linear projects (section 8.4) and move this plan's phases into them	D

Gate 1: main contains v2.5 and frontend-v1; CI is green on main; the only open PRs are active work; a production inventory exists and every difference in it is explained.

Phase 2 - Hotfix P22.2 and v2.5 on staging - Mon 19 -> Fri 30 Oct

#	Task	Owner
2.1	P22.2, a hotfix of v2.0 from main: atomic jwrite (only the admin.php/forms.php hunks of bd53b01), the admin / admin hints removed (S-03), a Throwable catch (B-03), the session-secret guard (B-02), an .htaccess deny for wx-*.php, and a sitemap without downloads/blocks	D
2.2	Package it under the manifest rules of tools/make-release.mjs (commit, file hashes, credential refusal); exclude wx-install.php, wx-check.php and wx-demo.php	D
2.3	Deploy P22.2, re-run the inventory, and confirm it matches the manifest	O + D
2.4	Create a staging subdomain (for example staging.woodex.com.pk) with a copy of the database	O
2.5	On staging: php db/migrate.php --status, then --dry-run, then run 000-014; compare row counts before and after	D
2.6	Deploy P25.x to staging at /admin-next/; run php db/owner.php --status	D

Gate 2: production matches the P22.2 manifest; staging runs migrations 000-014 cleanly; /api/v2/health answers on staging.

Phase 3 - v2.5 live beside v2.0 - Mon 2 -> Fri 13 Nov

#	Task	Owner
3.1	Run the host gate on staging (v2.5 plan Section 11): an editor publishes an article; one header change rolls across every page; it rolls back from page history; /api/v2/health is ok; the v2.0 /admin/ still works	D + O
3.2	Back up production; run the migrations there; deploy api/v2 and /admin-next/ (staff only)	D
3.3	Repeat the host gate on production and record the numbers in the v2.5 plan Section 11	D
3.4	Fix A-02 (secrets in the approval queue) before any manager uses Integrations in v2.5	D

Gate 3: v2.5 serves real data on production at /admin-next/; v2.0 is unaffected; the host gate has passed twice.

Phase 4 - Coverage and cut-over - Mon 16 Nov 2026 -> Fri 22 Jan 2027

The build order follows daily use, not the old menu.

Order	Scope	Why at this point
4a	Pipeline board and quotation builder as live screens over the existing api/v2 money path	Sales cannot move to v2.5 without them
4b	Invoices, payments, clients, bookings and the chat inbox, with every Phase 2 screen checked against production data	Daily operations
4c	The rest of v2.5 Phase 3: SEO screens, page_delete (trash + redirect), integration tests, pushes and Gmail, the 22-connector gallery	Website control
4d	v2.5 Phase 4: AI centre, knowledge base, WhatsApp hub, broadcasts and automation, Telegram, social planner	Marketing automation
4e	v2.5 Phase 5: backups (run, restore, download), monitoring (cron freshness, error rate), maintenance mode	Operations
4f	Cut-over: /admin/ sends a 302 to the v2.5 console; v2.0 is kept for 14 days, then removed from releases	-

Gate 4: every route the studio used in the last 30 days (from the activity log) works in v2.5 for every role; a restore from backup has been done on staging; 14 days have passed without a rollback.

Phase 5 - Data and platform hardening - in parallel, November 2026 -> January 2027

The work, in order:

- migration 003 (document columns for quotes and invoices);
- migration 004 (foreign keys, after cleaning up orphan records);
- migration 010 (JSON stores into MySQL);
- HttpOnly-cookie sign-in for everyone;
- a Content-Security-Policy on /admin/;
- off-site backups (Drive or GitHub) with a monthly restore test;
- uptime and error monitoring.

Gate 5: no business state remains in _private/*.json; money totals can be queried in SQL; the last off-site backup is less than 24 hours old.

Phase 6 - Growth features - February -> April 2027

- **Client portal.** Tokenised links with no login; the pattern already exists in quote-view.php. Clients approve BOQs, see renders and site progress, and pay a deposit. This is the core of the diaspora offer.
- **Payment gateway** (decision D-9).
- **AI scope generator:** a brief or floor plan becomes a draft BOQ, priced from the estimator rate book.
- **Inventory and purchase orders,** linked to Woodex Furniture production.
- **Real-time chat** (SSE).

Gate 6 (from the v2.5 plan): a client without an account opens a portal link, approves a quotation and pays a deposit, and the invoice reconciles itself.

6.1 Timeline at a glance

Weeks from 15 Oct	Engineering	Marketing
0 (15-17 Oct)	Phase 0 containment	-
1 (19-23 Oct)	Phase 1 consolidation; P22.2 build	NAP decision; Google Business Profile audit; social links and sameAs; fix the company profile
2 (26-30 Oct)	P22.2 live; staging and migrations	Proof sprint starts: consents, photos, client quotes
3-4 (2-13 Nov)	Host gate; v2.5 live beside v2.0	First 4 case studies live; logo wall; About page with the team
5-8 (16 Nov-11 Dec)	Pipeline, quotation builder and core screens	Reviews engine; diaspora landing page; first videos
9-12 (14 Dec-8 Jan)	Website-control and automation screens	2027 editions of the cost guides, published in the first week of January
13-14 (11-22 Jan)	System screens; cut-over	8+ case studies; quarterly KPI review
February-April 2027	Phase 6	Portal-led diaspora campaign

7. Website, SEO and marketing

7.1 Where Woodex already wins - protect this

- **Content depth.** 48 articles, including 14 cost and price guides (interior design, renovation, false ceilings, modular kitchens, wardrobes, office fit-out, architect fees and more) that answer the exact questions buyers ask.
- **Local coverage.** 12 city pages and 8 Lahore area pages: DHA, Bahria Town, Gulberg, Johar Town, Model Town, Cantt, Lake City, Wapda Town.
- **Tools no competitor has.** A cost estimator, site-visit booking, live chat with WhatsApp/Telegram hand-off, and client quotation links.
- **Technical SEO.** 0 broken links, schema on every page, fast static pages, and llms.txt with an explicit AI-crawler policy, so answer engines can quote Woodex.
- **One accountable team for design, build and furniture.** Woodex Furniture manufactures; competitors only claim this.

7.2 Competitor benchmark - five Lahore studios, checked 15 October

Sources: the mavric.pk, hiline.pk, spacezandplaces.com and interioreight.com home pages, fetched 15 Oct. For Aenzay, whose site returned HTTP 500 twice: its own pages and Facebook page as shown in search results. The first table compares **proof** (what makes a visitor trust a studio); the second compares **conversion and reach** (how a visitor becomes an enquiry).

Studio	Track record	Real projects shown	Named principal	Social profiles
Woodex	since 2016 - 200+ spaces	none - all 6 studies are illustrative	no	none linked
Mavric	not stated	named offices, restaurants and IT companies	yes - principal architect with credentials	Instagram, Facebook, LinkedIn, YouTube, Pinterest
Spaces & Places	since 2014	20+ client logos (Nestlé, Unilever, Red Bull, Decathlon, Jotun...)	not seen	not seen
HILINE	since 1969 - 100+ projects	a projects page	not seen	share buttons only
Interior Eight	19+ years - 500+ projects	a project gallery with covers	not seen	WhatsApp lines for Pakistan and the UAE
Aenzay	"11 years"; ISO 9001 / OHSAS 18001 claimed	interior, architecture and construction galleries	not seen	Facebook (374 reviews), YouTube, LinkedIn, Pinterest, TikTok

Studio	Platform	Main call to action	Pricing help	Keyword pages	Overseas clients
Woodex	static HTML + PHP, 142 pages	contact form, WhatsApp, live chat, estimator, site-visit booking	estimator + 14 cost guides	5/10 marla, 1/2 kanal, 12 cities, 8 Lahore areas	not addressed
Mavric	WordPress	WhatsApp quote, call	an FAQ on fees	5/10 marla, 1/2 kanal, farmhouse, villas	no
Spaces & Places	WordPress	call (the hero button uses a placeholder number)	-	a deep service tree	no
HILINE	WordPress	a short quote form on every service card	-	4 service lines	no
Interior Eight	custom build with a projects API	WhatsApp, Pakistan and UAE	a colour palette tool	-	yes (a UAE line)
Aenzay	WordPress	phone	long blog posts	Lahore, Islamabad	product rendering for US clients

7.3 Gaps -> actions

#	Action	Detail	KPI
G1	Proof sprint: real case studies	Start with 8 projects from the company profile, subject to consent (D-5): Peshawar Zalmi, University of Management and Technology, Devsinc, Hotel One Lahore, Al Haram City head office, the Jotun brand shop, the CDC / Care Pro diagnostic centres, the Car Switch head office. Label each one's scope honestly (full interior, fit-out or furniture supply). Each page gives client and sector, location, area, scope, timeline, before/after and 3D-vs-built photos, one client quote, and links to the services used. Keep the illustrative studies, but call them "Design studies". Defence-sector work (PAF) only with explicit clearance.	4 live by 13 Nov, 8 by 22 Jan; case-study -> enquiry rate
G2	Logo wall	Grow assets/data/clients.json from 6 logos, all automotive and fuel brands, to 20+ across sectors (education, sport, tech, healthcare, hospitality, real estate), with permission	logo count; home-page enquiry rate
G3	People	An About page with the founder or principal and the team: names, roles, qualifications and registrations (PCATP or PEC where they apply), and office and workshop photos	time on page; E-E-A-T

#	Action	Detail	KPI
G4	Entity graph and NAP	One official NAP per brand everywhere (D-6). Claim and optimise the Google Business Profile: category Interior designer, services, weekly photos, Q&A. Add sameAs links (GBP, Facebook, Instagram, LinkedIn, YouTube, Pinterest) to the Organization schema and social icons to the footer. Re-issue the company profile PDF without the spam phrase and with the correct NAP.	GBP calls, direction requests, website clicks
G5	Reviews engine	After every handover, send a WhatsApp message (the Cloud API is already integrated) with the Google review link. Show recent reviews on the site, but do not self-mark-up stars: Google ignores self-serving review markup for LocalBusiness.	+25 Google reviews in 90 days; rating 4.7 or higher
G6	Diaspora offer	"Build or finish your home in Pakistan from abroad": remote design through 3D, weekly photo and video site updates, a fixed BOQ and staged payments. Add an international WhatsApp number and pages for audiences in the UAE, Saudi Arabia, the UK and North America. Later, the client portal (Phase 6).	diaspora enquiries per month
G7	Video	A YouTube channel plus Reels: 3D walkthroughs, before/after, site progress. Embed them on case studies and service pages.	views; assisted enquiries
G8	Conversion	A short form on every service page (the HILINE pattern), and WhatsApp as the primary mobile call to action. Add GA4 events for form submit, WhatsApp click, call click and estimator completion. Target a first response under 15 minutes in business hours.	enquiry rate; first-response time
G9	Content upkeep	Refresh the cost guides every quarter and publish the 2027 editions in the first week of January. Add price-per-square-foot tables and FAQs. Publish one new article a week, drawn from real projects.	organic clicks (Search Console)
G10	Website basics	W-02 (alt text) and W-03 (CSS weight); blocks.html is removed in Phase 0	Core Web Vitals pass rate

7.4 Keyword focus - where the money is

Cluster	Target pages	Competitors also targeting it
"interior designer in Lahore", "interior design Lahore"	home, /interior-design/, /lahore/	all five
"5 marla / 10 marla / 1 kanal / 2 kanal house design"	the four plot-size pages + cost guides	Mavric
"office fit out Lahore", "office interior Lahore"	/office-fit-out/, /office-interior-design/ + B2B case studies (Devsinc, Car Switch, software houses)	HILINE, Spaces & Places
"restaurant / cafe interior design Lahore"	the restaurant and cafe pages	Mavric, Interior Eight
"renovation cost Lahore", "interior design cost Pakistan"	cost guides + estimator	Mavric (fee FAQ)
DHA / Bahria Town / Gulberg searches	the 8 Lahore area pages	Mavric and Spaces & Places (both DHA-based)

8. Operating model - how work is done from now on

8.1 Branches and pull requests

- main is the only long-lived branch, and every change arrives by PR with green CI.
- One PR has one purpose. No release zips, screenshots or credentials in any PR.
- Anything touching sign-in, installers, SQL seeds, .htaccess or _private/ needs the owner's approval in the PR.

8.2 Agent-session protocol

The repeated drift comes from several sessions working at once from different starting points: four admin generations, three of them built in parallel this week. Every session, human or agent:

1. Starts from main (after Phase 1), never from another session's branch unless told to.
2. Reads this plan and the status file first (WORK-SANDBOX-MEMORY.md, to be renamed STATUS.md).
3. Works on **one** Linear issue, and its PR links that issue.
4. Never writes a password, token or key into a file, a page, a PR description or a shared document. This is the same rule make-release.mjs enforces for packages.
5. Ends by updating the status file and the Linear issue.
6. Never shares an area (website, API or console) with another session at the same time.

8.3 Release discipline

- Packages are built only by tools/make-release.mjs. The manifest records the commit, the file hashes and the migrations.
- After every deployment, compare the production inventory with the manifest. Any difference is a failed release.
- Installers and diagnostics never ship. db/migrate.php and db/owner.php run from the command line.
- Release notes say what changed for the studio, not just for developers.

8.4 Linear structure (team MAR, plus a new engineering team)

Project	Target date	Labels
P0 Containment	17 Oct 2026	security, owner-action
P1 One source of truth	23 Oct 2026	repo, ci
P2 Hotfix P22.2 + staging	30 Oct 2026	security, backend
P3 v2.5 live beside v2.0	13 Nov 2026	admin-v25
P4 Coverage and cut-over	22 Jan 2027	admin-v25
P5 Data and platform hardening	29 Jan 2027	data, security
P6 Growth features	April 2027	product
M1 Proof and trust	22 Jan 2027	marketing, website
M2 Local SEO and reviews	11 Dec 2026	marketing
M3 Diaspora and video	11 Dec 2026	marketing

8.5 Documentation

Keep one plan (this file), one status file, and docs/ for everything else, with an index. Older plans move to docs/archive/ with a line at the top pointing here.

9. KPIs

Area	KPI	Baseline (15 Oct)	Target
Security	Critical findings open	6	0 by 17 Oct
Security	High findings open	13	0 by 13 Nov
Releases	Production files matching the release manifest	unknown	100% after every deployment
Engineering	CI green on main	no CI	100%
Engineering	Routes the studio uses daily that are live in v2.5	about 28 screens of 65 registered	100% before cut-over
Operations	Age of the last off-site backup	unknown	under 24 h; a restore test every month
Website	Core Web Vitals, mobile p75: LCP / INP / CLS	measure in week 1	under 2.5 s / 200 ms / 0.1
Website	Broken internal links	0	0
SEO	Organic clicks (Search Console)	measure in week 1	+40% by April 2027
SEO	Top-10 positions for 20 cluster keywords (section 7.4)	measure in week 1	12 of 20 by April 2027
Marketing	Real case studies live	0	4 by 13 Nov; 8 by 22 Jan
Marketing	Google reviews	measure in week 1	+25 in 90 days
Sales	Qualified enquiries per month (form + WhatsApp + chat + calls)	measure in week 1	+30% by 22 Jan
Sales	Median first response (business hours)	measure in week 1	under 15 min
Sales	Enquiry -> site visit -> quote -> won	measure in week 1	tracked monthly on the v2.5 dashboard

10. Risks

#	Risk	Chance	Impact	Mitigation
K1	Published credentials are used before rotation	Medium	Severe	Phase 0 today; review the Activity log; rotate everything
K2	Parallel sessions keep forking the work	High	High	The section 8.2 protocol; a protected main; one Linear issue per session
K3	Migrations damage live data	Low	Severe	Staging copy first; dry run; row-count check; a backup before every run
K4	Cut-over before the sales screens exist disrupts quoting	Medium	High	Gate 4: every route used in the last 30 days must work in v2.5
K5	Making the repository private breaks public links (GitHub zip links in docs, Drive and the old downloads.html)	High	Low	Move artifacts to Drive or Releases first and update the links
K6	Clients refuse to have their projects published	Medium	Medium	Ask early; publish anonymised versions (sector + area); logos only with permission
K7	Hostinger .htaccess quirks break the console's deep links	Medium	Medium	Test on staging first; scope the fallback to /admin-next/
K8	One developer becomes the bottleneck	Medium	High	Do P0-P3 first; P6 only after cut-over; the marketing track runs independently

Appendix A - Hour-0 checklist (printable)

Do these in order. They need hPanel, the Woodex admin, Google, Meta, Telegram and GitHub access.

1. hPanel -> Files -> **Backups**: download today's file backup and database backup.
2. hPanel -> Files -> **File Manager** -> public_html: delete downloads.html, blocks.html, wx-install.php, wx-check.php and wx-demo.php.
3. Open each of those five addresses on https://woodex.com.pk/ and confirm "Page not found".
4. In https://woodex.com.pk/admin/ -> Users, give every user a new strong password and deactivate users you do not recognise. Then go to My profile -> Security and turn on two-step sign-in for both owners.
5. Admin -> Activity: note any sign-in since 8 October that you do not recognise (date and IP).
6. hPanel -> Databases -> MySQL: change the database user's password, then update the password in public_html/_private/db.json and confirm the admin still opens.
7. Telegram -> @BotFather -> /revoke -> choose the Woodex bot; paste the new token into Admin -> Telegram.
8. Meta Business Suite -> System users: generate a new WhatsApp token and paste it into Admin -> WhatsApp settings. Then Admin -> WhatsApp automation -> Settings: create a new cron key and update the Hostinger cron job address.
9. Anthropic and OpenAI consoles: delete the old keys, create new ones, and paste them into Admin -> AI settings.
10. Google Cloud Console -> Credentials: reset the OAuth client secret if Google sign-in or Analytics uses one.
11. Admin -> Settings -> AI Agent (MCP): revoke every token; create new ones only where needed.
12. Admin -> page builder settings: change the page-builder password.
13. GitHub -> repository Settings -> General -> Danger zone -> Change visibility -> **Private**.
14. Google Search Console -> Removals -> New request for /downloads.html and /blocks.html; then Sitemaps -> resubmit.
15. Tell everyone with admin access that passwords have changed, and that credentials are never shared in files, pages or chats.

Appendix B - What to take from the v2.1 line before closing it

Item	Source	Goes to	Why
Atomic JSON writes (temp file + rename)	bd53b01: frontend-v1/api/admin.php:37-46, forms.php:24-33	hotfix P22.2	Closes B-01 in production now
A redraw once deferred screens have loaded (the VIEWS proxy)	bd53b01: frontend-v1/admin/admin.js, around line 317	P22.2 (optional)	Removes a blank first screen after a refresh
.gitignore entries (.env, .log, _private/, OS files)	bd53b01	main	Stops the next leak
.env.example	bd53b01	main (documentation)	Documents configuration without values
Dual-bank payment modal; 4-theme print switcher	c4461b3	the v2.5 backlog (Business and Templates screens)	Feature ideas, not hotfixes
Preline Ocean polish; PR #6's colour-token and chart-theming batches	720d817, PR #6	design reference for the v2.5 "Woodex Ink" tokens	No code transfer
Do not take: the root admin/ copy; woodex-database.sql (phantom tables + seeded owners); the preview password bypass; tools/v21-preview.mjs	-	-	Duplicates or risks

Appendix C - Repository disposition

Path	Size	Action
frontend-v1/	43 MB	Keep: the website, plus the v2.0 API and admin (rollback until cut-over)
api/v2/, admin-v25/, db/, tests/, ci/ (PR #7)	-	Keep: the development line
root admin/	4.2 MB	Delete (PR #7 does)
wf-admin/, netlify/, netlify.toml, vercel.json, api/router.mjs, supabase/	about 13.5 MB	Delete: retired by D11
the root site (87 pages: index.html, 71 page folders, assets/, content/)	about 10 MB	Delete after D-3, tagging it first
deploy/, woodex-vlive-P20/, woodex-master-P22/	about 237 MB	Move the releases to GitHub Releases or Drive and delete them from the tree (PR #7 removes most)
woodex-master-P25/*.zip (PR #7)	29 MB	Move to a release asset or Drive; keep MANIFEST.json and README.md
mcp-server/	76 KB	Delete: frontend-v1/api/mcp.php is the MCP endpoint on Hostinger
tools/*.png (42 files)	6 MB	Delete, or move to docs/screenshots/
24 root reports	about 0.4 MB	Move to docs/archive/ with an index
seo-audit/	0.8 MB	Move to docs/

Git history keeps every deleted byte. Shrinking the clone with git filter-repo is optional; it changes every commit id and breaks open PRs. Do it only after Phase 1 and after rotation, if at all.

Appendix D - How the numbers were measured

All checks are read-only and can be repeated from the repository root.

```
# branch state and the three commits of 15 Oct
git log --format='%h %ad %s' --date=iso 782b50b..HEAD
gh pr list --state all
gh api
repos/marketingwoodex-cloud/-marketingwoodex/compare/arena/4150341e-marketingwoodex...arena/5dbf54
61-marketingwoodex

# credentials on public branches: existence only, never the contents
gh api
"repos/marketingwoodex-cloud/-marketingwoodex/contents/.env?ref=arena/7f38fddd-marketingwoodex"
--jq .size

# PHP grammar (no PHP binary needed)
npm i php-parser@3 && node tools/phplint/lint.cjs $(find frontend-v1 -name '*.php')

# admin modules parse, screens registered more than once
for f in frontend-v1/admin/*.js; do node --check "$f"; done
grep -oE 'VIEWS\.[a-zA-Z0-9_]+ *= *function' frontend-v1/admin/*.js | sort -u | awk -F'VIEWS.'
'{print $2}' | sort | uniq -c | awk '$1>1'

# the five "tables" are functions
grep -rcE 'function wx_(allowed|caps|user_perms|action_group|role_groups)\b'
frontend-v1/api/roles-lib.php

# public site: internal links, alt text, titles, canonicals
# a Python walk over frontend-v1 (excluding admin/, builder/, api/, _private/)
# resolving every href/src that starts with "/" against the file tree
```

The PDF beside this file was rendered with tools/report2pdf.py from the v2.5 branch, with the L-05 width fix applied to a local copy; the Markdown is the source of truth.

Production checks were plain page loads of /, /admin/, /api/v2/health, /sitemap.xml, /downloads.html, /blocks.html, /wx-install.php, /wx-check.php and /wx-demo.php, made on 15 October 2026. No form was submitted and no sign-in was attempted.